

Klausur / Exam

Grundlagen der IT-Sicherheit /

Foundations of IT Security

H T
W I
G N

Prof. Dr. Hanno Langweg

2022-02-14T1400 – 2022-02-14T1530

- 12 Blätter inkl. Deckblatt
12 pages including this front page
- Bearbeitungsdauer: **90 Minuten**
*Available time **90 minutes***
- Zugelassene Hilfsmittel: Keine
No permitted examination aids
- Schreiben Sie Ihren Namen und Ihre Matrikelnummer auf **jede** Seite
*Write your name and student number on **each** page*
- Benutzen Sie nur das Klausurpapier (Rückseite, wenn nötig)
Use only paper handed out (use reverse side of page if necessary)
- Schreiben Sie **lesbar**. Verwenden Sie einen schwarzen oder blauen Stift, keinen roten oder grünen.
Write legibly. Use a black or a blue pen, do not use a red or a green one.

Name: _____

Matrikelnr.: _____ ☐ AIN ☐ WIN ☐ Anderer Studiengang
Student number Study programme (other)

Regelmäßige Teilnahme an der Lehrveranstaltung in diesem Semester: ☐ ja ☐ nein
I attended classes regularly during the semester: yes no

Allen, die gelernt
haben, wünsche ich
viel Erfolg und allen
anderen viel Glück!

Good luck!

1. IT-Grundschutz / IT Base Protection (6%)
2. Ransomware (8%+7%=15%)
3. Positivlisten / Whitelisting (8%+2%+6%+4%=20%)
4. Zugriffssteuerung / Access Control (4%)
5. Hashen von Passwörtern / Password Hashing
(2%+2%+2%+2%+2%+2%+2%+2%=16%)
6. Lieferkettensicherheit / Supply Chain Security
(10%+5%=15%)
7. Zertifizierung / Certification (6%+4%+4%=14%)

1. IT-Grundschutz / IT Base Protection (6%)

Kreuzen Sie alle richtigen und nur die richtigen Antworten an.

Mark all correct answers and only correct answers.

Was müssen Sie prüfen, wenn Sie die Umsetzung von Sicherheitsmaßnahmen planen?

What do you need to check when planning the implementation of security controls?

- ☐ Welche begleitenden Maßnahmen für eine erfolgreiche Umsetzung erforderlich sind
Which accompanying measure are necessary for a successful implementation
- ☐ Ob die betreffende Maßnahme bereits eingeführt ist
If the control has been implemented already
- ☐ Ob die Maßnahme mit anderen Maßnahmen vereinbar ist
If the control is compatible with other controls
- ☐ In welcher Reihenfolge die verschiedenen Maßnahmen umgesetzt werden sollen
In what order the various controls should be implemented

Was unternehmen Sie als Informationssicherheitsbeauftragter, wenn die Leitung Ihrer Institution nicht bereit ist, den Aufwand für eine bestimmte Sicherheitsmaßnahme zu tragen?

What do you do as Information Security Officer when the management of your organisation is not willing to bear the effort for a specific security control?

- ☐ Sie verdeutlichen ihr, welche Risiken mit dem Fehlen der Maßnahme verbunden sind.
You make clear what risks are associated with the missing security control
- ☐ Sie bitten die Leitung, durch Unterschrift zu bestätigen, dass sie die damit verbundenen Gefahren kennt und trägt.
You ask management for written confirmation that it is aware of the risk and is willing to take it.
- ☐ Sie ignorieren die Leitung und setzen die Maßnahme trotzdem um.
You ignore management and implement the controls anyway.
- ☐ Sie verzichten auf eine unmittelbare Reaktion, nehmen sich aber vor, nach Ablauf einer gewissen Zeitspanne die Zustimmung der Leitung einzuholen.
You do not react immediately, but you plan for getting management support after a certain time has passed.

Wer sollte in der Regel technische Maßnahmen zur Absicherung eines bestimmten IT-Systems umsetzen?

Who should usually implement technical controls to secure a specific IT system?

- ☐ Die Leitung der IT-Abteilung
The head of the IT department
- ☐ Der Informationssicherheitsbeauftragte
The information Security Officer
- ☐ Der zuständige Systemadministrator
The responsible system administrator
- ☐ Der Benutzer des IT-Systems
The user of the IT system

2. Ransomware (8%+7%=15%)

Bei einem sogenannten Ransomware-Angriff (Ransom engl. Lösegeld, Ransomware = Ransom+Malware) verschaffen sich Angreifer Zugang zum Gerät eines Betroffenen und verschlüsseln Daten auf dem Gerät. Anschließend verlangen die Angreifer Geld im Austausch gegen das Versprechen der Entschlüsselung.

*In a ransomware attack (**ransom+malware**), attackers – after obtaining access to a victim's machine – encrypt a victim's data and request money in exchange for decrypting the data.*

- a) Zwei übliche Angriffsvektoren für Ransomware sind die Ausführung von Schadsoftware oder das Ausnutzen einer Softwareschwachstelle in einem Netzwerkdienst. Nennen Sie für diese beiden Angriffsvektoren je ein geeignetes Entwurfsprinzip von Saltzer und Schroeder, gegen das verstoßen wird, um den Angriff zu ermöglichen. Nennen Sie für jeden der beiden Angriffsvektoren eine geeignete Schutzmaßnahme.

Two typical attack vectors for ransomware are execution of malware or exploitation of a software vulnerability in a network service. Name for each of the two attack vectors a suitable design principle of Saltzer and Schroeder that is violated to enable the attack. Name for each of the two attack vectors an appropriate protection mechanism.

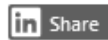
- b) Lesen Sie den Artikel (auf der nächsten Seite) zum Ransomware-Angriff bei Swissport. Nennen Sie unter Bezug auf den Artikel relevante Prozess- und System-Bausteine des IT-Grundschutz (mit Baustein-ID), welche die Fortsetzung des Geschäftsbetriebs nach einem Ransomware-Angriff unterstützen.

Read the article (on the next page) about the ransomware attack at Swissport. With reference to the article, list relevant process modules and system modules of IT-Grundschutz (incl. module id) that ensure business continuity after a ransomware attack.



Ransomware Attack on Aviation Services Firm Swissport Leads to Flight Delays

By Eduard Kovacs on February 07, 2022



Aviation services company Swissport on Friday said it was targeted in a cyberattack that has caused some disruption to its operations.

The Switzerland-based company provides airport ground services and air cargo handling, with operations at 285 airports in 45 countries. Last year, Swissport said it had served 97 million airline passengers and handled more than 5 million tons of air freight.

On February 4, Swissport said on Twitter that its IT infrastructure was hit by ransomware.



Swissport
@swissportNews

...

⚠ A part of #Swissport's IT infrastructure was subject to a ransomware attack. The attack has been largely contained, and we are working actively to fully resolve the issue as quickly as possible. Swissport regrets any impact the incidence has had on our service delivery.

2:50 PM · Feb 4, 2022 · Twitter Web App

The company told *SecurityWeek* in a statement on Monday that the breach was detected on February 3 and that it has been contained.

"The affected infrastructure was quickly taken offline and manual workarounds or fallback systems have remained operational. A full system clean-up and recovery is now underway and we do not expect any significant delays," Swissport stated.

Swissport's website is now back online after it was inaccessible when the attack was disclosed.

The company could not share any information on the type of ransomware used or whether the attackers had managed to steal any data.

It's unclear how many airports are impacted by the incident, but German publication *Der Spiegel* learned that the attack caused some temporary delays at Zurich Airport. The airport's representatives said there was no significant impact on flight operations, but admitted that 22 flights were delayed by 3 - 20 minutes due to the incident.

American Shipper **reported** that Swissport had switched to paper manifests at Brussels Airport.

Source: <https://www.securityweek.com/ransomware-attack-aviation-services-firm-swissport-leads-flight-delays>

3. Positivlisten / Whitelisting (8%+2%+6%+4%=20%)

Positivlisten für Anwendungsprogramme regeln, dass nur solche Anwendungsprogramme ausgeführt werden können, die von der Organisation für ein Benutzerkonto oder für ein Gerät zugelassen worden sind. Für Microsoft Windows werden Positivlisten beispielsweise mittels AppLocker und Windows Defender Application Control (WDAC) umgesetzt.

Whitelists for applications can be used to enforce that only those applications can be executed that are specifically allowed by an organisation for a user account or for a device. For Microsoft Windows, application whitelists can be managed using, e.g., AppLocker and Windows Defender Application Control (WDAC).

- a) Beschreiben Sie die Funktionsweise von AppLocker oder WDAC.
Describe how AppLocker or WDAC works.

- b) Wozu dient der Audit Mode?
What is the purpose of the audit mode?

Name: _____

Matrikelnr.: _____

- c) Welchen konkreten Inhalt empfehlen Sie für die Positivliste (Whitelist) für einen Arbeitsplatz-PC in der Verwaltung einer Hochschule? Antworten Sie, ohne die im einzelnen benötigten Anwendungsprogramme zu kennen.

What specific content of a whitelist do you recommend for a personal computer of the administrative department of a university? Answer without knowing the particular applications that are used.

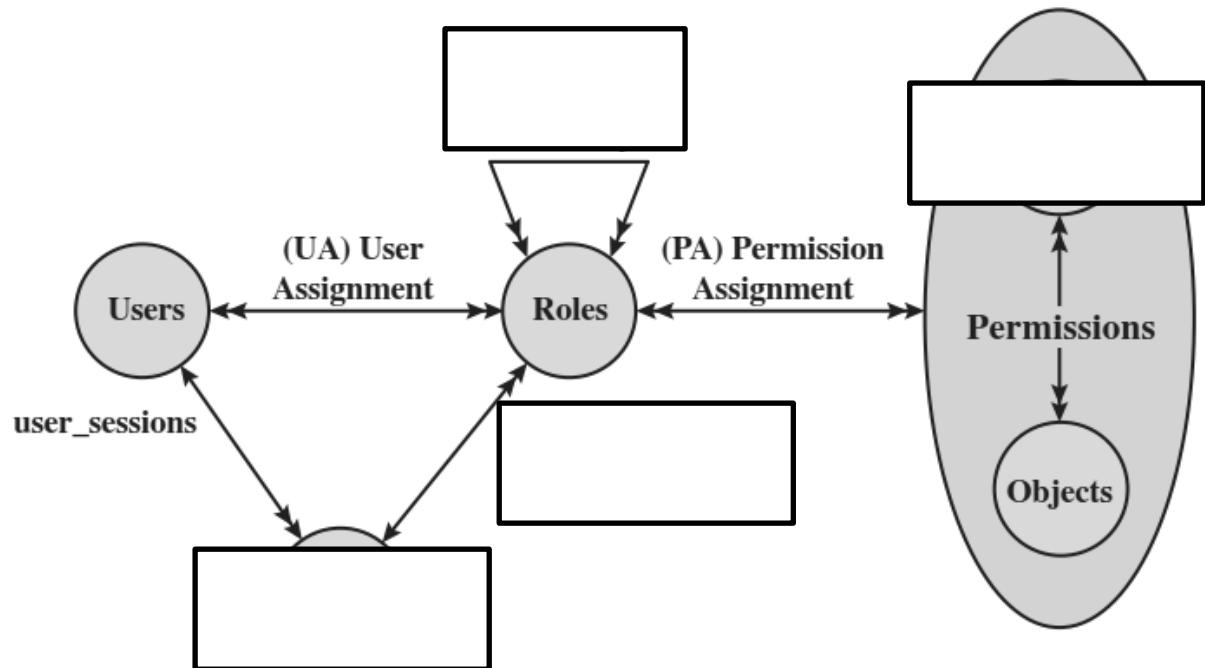
- d) Welche Herausforderungen sehen Sie für Positivlisten in PC-Pools einer Hochschule? Welche zusätzlichen oder alternativen Schutzmechanismen empfehlen Sie bei einer geplanten Einführung von Positivlisten für PC-Pools?

What challenges do you see for whitelists for computer labs at a university? What additional or alternative protection mechanisms do you recommend for a planned introduction of whitelists for computer labs?

4. Zugriffssteuerung / Access Control (4%)

Komplettieren Sie das nachfolgende Diagramm bezüglich RBAC Role Based Access Control.

Complete the diagram with respect to role-based access control (RBAC).



Stallings/Brown (2015). Computer Security. Fig. 4.8

5. Hashen von Passwörtern / Password Hashing (2%+2%+2%+2%+2%+2%+2%+2%=16%)

Passwörter sind eine der am weitesten verbreiteten Authentisierungstechniken.

Passwords are among the most widely used authentication mechanisms.

- a) Was ist die minimale Länge von Passwörtern an der HTWG Konstanz?
What is the minimum length of passwords at HTWG Konstanz?

- b) Passwörter werden nicht im Klartext, sondern es wird ihr Hash-Wert gespeichert. Warum?
Passwords are not stored in cleartext, instead, their hash value is stored. Why?

Name: _____

Matrikelnr.: _____

- c) Was ist eine Hashfunktion?
What is a hash function?

- d) Was zeichnet eine gute Hashfunktion für Passwörter aus?
What characterises a good hash function for passwords?

- e) Nennen Sie eine gute Hashfunktion.
Name a good hash function.

- f) Was versteht man unter Salting von Passwörtern?
What is salting of passwords?

- g) Muss ein Salt-Wert geheim gehalten werden?
Does a salt value need to be secret?

- h) Microsoft Office verwendet dieselbe Hashfunktion 100.000 mal hintereinander. Helfen viele Iterationen auch gegen Angriffe mit Rainbow Tables oder reduzieren Rainbow Tables Angriffe stets auf eine feste Dauer?
Microsoft Office uses the same hash function iteratively 100,000 times. Do many iterations also help against attacks with rainbow tables or do rainbow tables reduce attacks always to a fixed duration?

7. Zertifizierung / Certification (6%+4%+4%=14%)

Die Foobar-Software der ACME Corp. hat eine EAL4-Evaluierung nach Common Criteria erfolgreich abgeschlossen.

The Foobar software of ACME Corp. was successfully evaluated at EAL4 according to the Common Criteria product evaluation scheme.

- a) Was können Sie über die Aktivitäten der Evaluatorin bei EAL4 konkret aussagen?
What can you tell about the specific activities performed by the evaluator at EAL4?

- b) Welche Teile des Security Targets lesen Sie zuerst und warum?
What parts of the Security Target do you read first and why?

Name: _____ Matrikelnr.: _____

- c) Was ist ein Hauptkritikpunkt bei CC-Evaluationen? Welche Lösungsansätze verfolgen alternative Evaluierungsschemata (z.B. die Beschleunigte Sicherheits-Zertifizierung des BSI)?
What is a major point of concern for CC evaluations? How do alternative schemes (e.g. Accelerated Security Certification by BSI) address that criticism?
